

SECURENEST HR SOLUTIONS

Identity Lifecycle Management Review

Prepared by: Pavithra Tippareddy
Date: June 2026
Classification: Confidential
Version: 1.0
Platform: Microsoft Entra ID (Free Tier)

Framework References:

ISO 27001 Annex A.9.2.1 / A.9.2.6 | NIST CSF PR.AC | GDPR Article 5(1)(f)

1. EXECUTIVE SUMMARY

This review was conducted for SecureNest HR Solutions, a fictional 60-person HR consulting firm handling sensitive employee data across client organizations. The objective was to design and implement a full Identity Lifecycle Management (ILM) framework covering the Joiner, Mover, Leaver (JML) process, attribute-based group design, B2B external identity governance, and least-privilege role delegation.

Unlike a static access matrix review, this project demonstrates the dynamic, ongoing nature of identity management — simulating a complete employee lifecycle from onboarding through role change to offboarding, plus the onboarding of an external auditor as a B2B guest identity.

The project was implemented in a live Microsoft Entra ID Free Tier tenant. Three security groups were designed with documented dynamic membership rules (a P1 feature not available on free tier) and implemented as assigned groups to simulate the same governance outcome manually.

2. METHODOLOGY

This review applied identity lifecycle management principles aligned with:

- ISO 27001 Annex A.9.2.1 — User registration and de-registration
- ISO 27001 Annex A.9.2.6 — Removal or adjustment of access rights
- NIST CSF PR.AC — Identity management and access control
- GDPR Article 5(1)(f) — Integrity and confidentiality of personal data

Implementation approach:

- 6 user identities provisioned with realistic attributes (Job Title, Department, Company, Usage Location)
- 3 security groups designed with documented dynamic membership rules, implemented as Assigned groups due to free-tier licensing constraints
- Full Joiner/Mover/Leaver lifecycle simulated for one user (Frank Miller) with audit log evidence at each stage
- B2B guest identity onboarded for an external HR auditor, scoped to a dedicated read-only group
- Least-privilege directory roles assigned — Helpdesk Administrator and User Administrator instead of Global Administrator

3. USER INVENTORY & GROUP DESIGN

Six identities were provisioned to represent SecureNest's workforce structure:

Name	Job Title	Department	Group	Status
SN-Alice Johnson	HR Consultant	HR Operations	SN-HR-Consultants	Active
SN-Bob Chen	Senior HR Consultant	HR Operations	SN-HR-Consultants	Active
SN-Carol White	Payroll Specialist	Finance	SN-Payroll-Access	Active
SN-David Park	IT Support Specialist	IT	—	Active
SN-Emma Davis	External HR Auditor	External (Guest)	SN-External-Auditors	Active (Guest)
SN-Frank Miller	(offboarded)	(cleared)	(removed)	Disabled

Dynamic Group Design (documented as P1 feature):

Group Name	Intended Dynamic Rule (P1)	Purpose
SN-HR-Consultants	user.companyName -eq "SecureNest HR Solutions" -and user.department -eq "HR Operations"	HR systems access
SN-Payroll-Access	user.jobTitle -eq "Payroll Specialist"	Finance & Payment Gateway access
SN-External-Auditors	user.userType -eq "Guest"	Read-only audit access

Note: Entra ID Free Tier does not support Dynamic User groups — this requires a P1 license. All three groups were implemented as Assigned groups with manually managed membership to demonstrate the same access outcome, and the intended dynamic rule was documented for each as the production-ready design.

4. RISK FINDINGS & DESIGN DECISIONS

Finding 1 — Dynamic Groups Unavailable on Free Tier

Field	Detail
Affected Area	All 3 security groups
Limitation	Dynamic User membership requires Entra ID P1
Severity	MEDIUM (Operational Risk)
Reference	NIST CSF PR.AC — Identity Management

Risk Description:

Without dynamic groups, group membership must be manually updated whenever a user's role or attributes change. In a 60-person organization this is manageable, but at scale it introduces delay and human error risk — a user promoted or reassigned may retain old access until someone remembers to update their group membership manually.

Recommendation:

- Upgrade to Entra ID P1 to enable Dynamic User groups
- Implement the documented dynamic rules immediately upon upgrade — rules were pre-designed and tested conceptually during this review
- Until upgraded, implement a quarterly manual access review to catch any membership drift

INTERVIEW ANSWER GUIDE

"One of my findings in the SecureNest project was that dynamic groups require Entra ID P1, which wasn't available on the free tier I was working with. I designed the dynamic group rules anyway — for example, a rule like user.jobTitle -eq Payroll Specialist for the payroll access group — and documented them as the production-ready design, while implementing the groups as Assigned groups to simulate the same access outcome manually. I rated this Medium severity because in a small organization manual management is workable, but it doesn't scale — if

someone changes role and nobody remembers to update their group membership, they could retain access they no longer need. My recommendation was a P1 upgrade plus a quarterly manual review as an interim control."

Finding 2 — Least-Privilege Role Delegation Applied Correctly

Field	Detail
Affected Roles	David Park (IT Support), Bob Chen (Senior HR)
Access Level	Helpdesk Administrator / User Administrator
Severity	INFORMATIONAL (Positive Control)
Reference	ISO 27001 Annex A.9.2.3

Risk Description:

No violation found. Rather than assigning Global Administrator to IT Support staff — a common over-provisioning mistake — David Park was scoped to Helpdesk Administrator, which permits password resets and session management for standard users only, with no access to tenant settings or admin accounts. Bob Chen, as a senior HR consultant handling onboarding, was scoped to User Administrator rather than a broader role.

Recommendation:

- Maintain this scoping standard as the default starting point for any new role requiring administrative capability
- Document a role-to-permission mapping policy so future hires are scoped consistently rather than defaulting to broader access for convenience

INTERVIEW ANSWER GUIDE

"A positive finding from this project was around role delegation. Instead of giving IT Support Global Administrator — which is unfortunately common in smaller organizations because it's the easy default — I scoped David Park to Helpdesk Administrator. That role can reset passwords and manage sessions for standard users, but it cannot touch admin accounts or tenant-wide settings. ISO 27001 Annex A.9.2.3 requires that privileged access is allocated on a need-to-use basis, and Helpdesk Administrator is the minimum role that lets David do his actual job. The same principle applied to Bob Chen — User Administrator rather than a broader role, since his work is specifically account management for HR onboarding. This limits the blast radius significantly if either account is ever compromised."

Finding 3 — B2B Guest Identity for External Auditor

Field	Detail
Affected Role	External HR Auditor (Emma Davis)

Access Level	Guest — scoped to SN-External-Auditors
Severity	INFORMATIONAL (Positive Control)
Reference	ISO 27001 Annex A.9.2.1; GDPR Art. 5(1)(f)

Risk Description:

The external auditor was onboarded as a B2B guest rather than a standard member account. This means SecureNest is not responsible for managing her password or MFA enrollment — she authenticates with her own organization's identity — while still being placed in a dedicated, scoped group limiting her to read-only audit access. This is the correct pattern for any temporary or external personnel handling sensitive HR data, which carries GDPR obligations.

Recommendation:

- For future external engagements, use Entitlement Management Access Packages with a defined expiration date rather than indefinite guest access (a P1/P2 feature — documented as a future enhancement)
- Conduct a guest access review at the end of every audit engagement to confirm timely removal

INTERVIEW ANSWER GUIDE

"The external auditor in this project was onboarded as a B2B guest rather than a full member account, which is the correct pattern for temporary external personnel. She authenticates with her own organization's credentials, so SecureNest isn't managing a separate password or MFA enrollment for her, and she's scoped to a dedicated External Auditors group with read-only intent. Since she's handling HR data, GDPR Article 5(1)(f) is relevant here — personal data needs appropriate access restriction, and scoping a guest account to exactly what's needed, rather than giving her a full employee-equivalent account, satisfies that. If I had P1 available, I'd use an Entitlement Management Access Package with a hard expiration date tied to the audit engagement length, so her access would expire automatically rather than relying on someone remembering to remove it."

5. JOINER / MOVER / LEAVER LIFECYCLE — FRANK MILLER

To demonstrate full identity lifecycle management, a complete employee journey was simulated for one user, Frank Miller, covering onboarding, a role promotion, and final offboarding.

Joiner

Frank Miller was provisioned as an HR Consultant in the HR Operations department, with Company Name (SecureNest HR Solutions) and Usage Location (Finland) populated to reflect a realistic onboarding record. He was added to the SN-HR-Consultants group, granting access aligned with his role.

Evidence: 10_joiner_frank_onboarded.png

Mover

Frank was promoted to Senior HR Consultant, with his Department updated to HR Leadership. In a production environment with Entra ID P1, this attribute change would automatically trigger dynamic group re-evaluation — potentially moving him into a leadership-specific access group without manual intervention. On the free tier, this remains a manual step, which is documented as a limitation in Finding 1.

Evidence: 11_mover_frank_promoted.png

Leaver

Frank's offboarding followed a structured sequence: account disabled, active sessions revoked (forcing immediate sign-out), removed from the SN-HR-Consultants group, and his Job Title and Department fields cleared to reflect deprovisioned status. Each step was confirmed in the Entra ID audit log.

Evidence: 12_leaver_frank_disabled.png, 13_leaver_frank_removed_from_group.png

Audit Trail

The complete lifecycle — provisioning, attribute updates, group membership changes, session revocation, and account disablement — is captured in the Entra ID audit log with timestamps and actor information, providing a fully evidenced identity lifecycle record.

Evidence: 14_audit_log_securenest.png

6. RECOMMENDATIONS SUMMARY

#	Area	Severity	Recommended Action	Priority
1	Dynamic groups unavailable	Medium	Upgrade to P1; interim quarterly manual access review	Planned
2	Role delegation	Info	Maintain least-privilege scoping standard for all new admin roles	Ongoing
3	B2B guest access	Info	Move to Access Packages with defined expiration once P1/P2 available	Planned

APPENDIX — FRAMEWORK REFERENCE GUIDE

Quick reference for the standards cited in this report. Use this section for interview preparation.

ISO 27001 Annex A.9.2.1 — User Registration and De-registration

Requires a formal process for granting and revoking access as users join or leave the organization. Direct basis for the Joiner and Leaver stages of this project.

ISO 27001 Annex A.9.2.6 — Removal or Adjustment of Access Rights

Requires that access rights are removed or adjusted promptly when a person's role changes or their employment ends. Direct basis for the Mover and Leaver stages, and for Finding 1 on dynamic group automation.

NIST Cybersecurity Framework — Protect (PR.AC)

Covers identity management and access control as a core protect function, including the full lifecycle of identity provisioning, modification, and deprovisioning demonstrated in this project.

GDPR Article 5(1)(f) — Integrity and Confidentiality

Requires personal data to be processed with appropriate security, including protection against unauthorised access. Relevant to the external auditor's guest access to HR data, and to HR personal data generally within SecureNest's systems.